# Evidence to authorization to containment

PowerShell runbook for starting Guardian, receiving Twin evidence, checking trust, requesting a signed exact-action token, and handling an isolate request.

| IMPLEMENTED AND TESTED LOCALLY | PROPOSED / NOT JOINTLY TESTED |
| --- | --- |
| Twin-event ingestion/scoring; Brain verdict/authorization tools; Ed25519 token issue/verify; local audit. | Safe preview; real Twin containment; notifications; Twin-side token verification. |

**Guardian owns trust, authorization, and containment. Brain plans and requests authorization. Guardian scores evidence and signs tokens. Twin executes actions and enforces caps. Scores never replace tokens; RF is advisory with zero numeric trust weight.**

**Local tests do not prove partner integration. Partner-dependent steps below are identified as unconfirmed.**

# 1. Prepare and start Guardian

Run from the project folder. Install pinned dependencies and generate a persistent key pair once. Keep the private key on Guardian; provide only the public key via an agreed channel.

```
Set-Location "$env:USERPROFILE\Desktop\guardian"
if (!(Test-Path '.venv\Scripts\python.exe')) { python -m venv .venv }
.\.venv\Scripts\python.exe -m pip install -r requirements.txt
New-Item -ItemType Directory -Force secrets | Out-Null
.\.venv\Scripts\python.exe .\src\generate_token_keys.py --private .\secrets\guardian-ed25519-private.pem --
public .\secrets\guardian-ed25519-public.pem
```

Terminal 1: set separate API and Brain MCP keys, Twin values, and token key paths. Replace all placeholders with values from peer owners.

```
$env:DEMO_MODE = 'false'
$env:GUARDIAN_API_BEARER_KEY = '<guardian-api-key>'
$env:GUARDIAN_BRAIN_MCP_BEARER_KEY = '<brain-mcp-key>'
$env:TWIN_BASE_URL = '<twin-base-url>'
$env:GUARDIAN_TWIN_BEARER_KEY = '<twin-issued-key>'
$env:GUARDIAN_TOKEN_PRIVATE_KEY = (Join-Path (Get-Location) 'secrets\guardian-ed25519-private.pem')
$env:GUARDIAN_TOKEN_PUBLIC_KEY = (Join-Path (Get-Location) 'secrets\guardian-ed25519-public.pem')
$env:GUARDIAN_TOKEN_KID = '<partner-registered-key-id>'
.\.venv\Scripts\python.exe .\src\run.py
```

**Service URL is http://127.0.0.1:5000. Keep Terminal 1 open. DEMO_MODE=true is local-demo-only and bypasses protected-route authentication.**

# 2. Start Twin evidence ingestion

Terminal 2 consumes Twin SSE and submits readings to Guardian. Use the same API key as Terminal 1.

```
Set-Location "$env:USERPROFILE\Desktop\guardian"
$env:TWIN_BASE_URL = '<twin-base-url>'
$env:GUARDIAN_TWIN_BEARER_KEY = '<twin-issued-key>'
$env:GUARDIAN_API_BEARER_KEY = '<same-api-key-as-terminal-1>'
$env:GUARDIAN_LOCAL_URL = 'http://127.0.0.1:5000'
.\.venv\Scripts\python.exe .\src\twin_runner.py
```

At first run, Guardian attempts MCP discovery of list_actions, get_clock, list_nodes, and get_containment_state with a 3 real-second bound. Names/schemas are placeholders. Discovery failure does not stop evidence scoring, but blocks authorization.

# 3. Receive evidence and check trust

The runner handles live SSE. For an isolated smoke test, post one Twin-shaped reading directly; do not manually repost the same event while the runner consumes the live feed.

```
$reading = @{ run_id='run-42'; reading_id='traffic-17'; device_id='TC-01'; node_id='TRAFFIC-01';
timestamp='2026-10-23T12:00:00.000Z'; tick=17; sensor='congestion_index'; channel=$null; value=45.0;
unit='percent'; lat=36.5; lon=11.5 }
$event = @{ event='readings'; data=@{ run_id='run-42'; readings=@($reading) } } | ConvertTo-Json -Depth 8
$headers = @{ Authorization = "Bearer $env:GUARDIAN_API_BEARER_KEY" }
$result = Invoke-RestMethod -Method Post -Uri 'http://127.0.0.1:5000/api/integrations/twin/event' -Headers
$headers -ContentType 'application/json' -Body $event
$result | ConvertTo-Json -Depth 12
```

Inspect processed, skipped, duplicates, twin_discovery, and results[].evaluation. Guardian trust and RF advisory are separate. Identical redelivery is ignored; changed payload under the same reading ID is rejected. Brain requests get_trust_verdict(reading_id, fresh=true) over MCP; fresh scoring does not add another reputation penalty.

**Current thresholds: Trusted >= 0.7; Degraded > 0.3 and < 0.7; Untrusted <= 0.3. Provisional minima: R1 0.5, R2 0.7, R3 0.85. A synthetic water sequence ending at 180 cm scored 0.75 on its focus reading, 0.10 below R3; this was not live Twin data.**

Check readiness/capabilities:

```
Invoke-RestMethod 'http://127.0.0.1:5000/health' | ConvertTo-Json -Depth 8
Invoke-RestMethod 'http://127.0.0.1:5000/api/capabilities' | ConvertTo-Json -Depth 10
```

# 4. Request signed exact-action authorization

Brain calls Guardian MCP authorize_action with run_id, reading_ids, action, targets, params, risk_level, domain, and idempotency_key. The equivalent API request is:

```
$authorization = @{ run_id='run-42'; reading_id='traffic-17'; reading_ids=@('traffic-17');
action='set_signal_plan'; targets=@('TRAFFIC-01'); parameters=@{plan='favor_main_road'}; risk_level='R1';
domain='Traffic'; idempotency_key='run-42-traffic-17-signal-1' } | ConvertTo-Json -Depth 8
$approved = Invoke-RestMethod -Method Post -Uri 'http://127.0.0.1:5000/api/actions/authorize' -Headers
$headers -ContentType 'application/json' -Body $authorization
$approved | Select-Object decision, action, token_id, expires_at
```

**Approval requires configured keys, Twin discovery and clock, action manifest match, fresh evidence, and policy approval. Refusal returns no token. R3 valve and grid-switch requests currently refuse because safe preview is not implemented.**

Guardian signs g1 Ed25519 claims binding action, targets, params, idempotency key, reading IDs, key ID, and expiry 60 simulated seconds later. Give the token to the approved Twin verifier securely; never log/paste the full token. Local /api/actions/verify is for tests, not proof Twin verified it.

**A refusal means the action did not happen. A lost reply from a future execution request means unknown outcome; do not retry with a new idempotency key.**

# 5. Isolate / containment request

**Guardian-to-Twin isolate/quarantine/rollback/release calls are not implemented. Current Guardian isolate/quarantine routes change local simulation state only; they are not real containment.**

After Twin confirms the exact tool name and schema, the one-off MCP client can smoke-test it. Pattern only; not runnable until confirmed:

```
$tool = '<Twin-confirmed-isolate-tool>'
$args = '<Twin-confirmed-JSON-arguments>'
.\.venv\Scripts\python.exe .\src\twin_runner.py --tool $tool --arguments $args
```

The full containment flow still needs implementation: send a stable-key request, read Twin state, audit result, and notify Brain using a CIVIS-confirmed channel. CAP_EXCEEDED and DEVICE_QUARANTINED are refusals. A lost reply is unknown outcome. Power all-node isolation can cut Guardian sensor visibility; it does not turn off grid power.

# 6. Audit, verify, troubleshoot

Audit JSONL is written to run-logs/.guardian.jsonl and redacts full tokens, signatures, bearer keys, and private keys.

```
Get-Content .\run-logs\run-42.guardian.jsonl -Tail 30
.\.venv\Scripts\python.exe -m pytest -q tests
```

Latest suite: 51 passed, 2 skipped. Skips require live Twin access; canned discovery peers do not prove Twin behavior.

## Common outcomes

| Outcome | Meaning / next step |
|---|---|
| 401 invalid bearer | Use the key for that peer; API, Brain MCP, and Twin keys are distinct. |
| 503 discovery unavailable | Check Twin URL/key, MCP reachability, tool names, timeout. No token issues. |
| safe preview unconfirmed | Expected for R3/grid until preview is confirmed and implemented. |
| action not in manifest | Check normalized action against Twin's discovered list. |
| risk minimum not met | Correct refusal; do not lower policy thresholds. |
| duplicate / changed payload | Identical redelivery ignored; changed same-ID content rejected. |

## Open confirmations

Twin: discovery/preview/containment names and schemas, cap semantics, token audience/key registration, simulated clock and replay-verification contract. CIVIS: approve Brain MCP schema and containment-notification transport/payload/ack. Policy owners: approve cutoffs and risk minima.

References: README.md, INTEGRATION.md, INTERFACE.md, G7_NUMBERS.md, docs/TOKEN.md. Partner-dependent steps remain proposed and unverified.